SPIKA TECH™

PROCEDIMIENTO DE GESTIÓN DE NO CONFORMIDADES Y ACCIONES CORRECTIVAS

HISTORIAL DEL DOCUMENTO			
Versión	**Resumen de modificaciones**	**Fecha de entrada**	**Sustituye a (Código, revisión)**
01	Primera versión del documento.	26/02/2025	N/A

REGISTRO DE FIRMAS			
Función:	**Elaborado por:**	**Revisado por:**	**Aprobado por:**
Departamento:	Responsable del SGSI	Dirección	Jefe de seguridad (o suplente)
Nombre:	David Pozo	Carlos Rodrigo	Carlos Zúñiga
Firma:	Firmado por POZO SANCHEZ DAVID - ***6992** el día 26/02/2025	Firmado por RODRIGO RIVERO, CARLOS (AUTENTICACIÓN) el día 26/02/2025 con	Firmado por ***8264** CARLOS ZUÑIGA (R: ****8690*) el día 26/02/2025 con un
Fecha:	26/02/2025	26/02/2025	26/02/2025

CONTENIDO

1 OBJETIVO 4
2 ALCANCE 4
3 NORMATIVA APLICABLE 4
4 METODOLOGÍA DE GESTIÓN DE RIESGOS DESARROLLO 4
4.1 GESTIÓN DE NO CONFORMIDADES 4
4.2 DETECCIÓN E IDENTIFICACIÓN DE NO CONFORMIDADES 5
4.3 EVALUACIÓN DE NO CONFORMIDADES 5
4.4 TRATAMIENTO DE LAS NO CONFORMIDADES 5
4.5 MITIGACIÓN DE LA NO CONFORMIDAD 7
4.6 SEGUIMIENTO Y CIERRE 7
5 REGISTROS Y ARCHIVOS 7
6 REFERENCIAS 8

1 OBJETIVO

El presente documento recoge el procedimiento y describe las acciones que deben realizarse para la correcta gestión de las no conformidades detectadas en el sistema de gestión de seguridad de la información de SPIKA TECH. En concreto, en el presente procedimiento se establece:

- Detección e identificación de No Conformidades.
- Evaluación y tratamiento de las No Conformidades detectadas.
- Seguimiento y cierre de las No Conformidades.

2 ALCANCE

Este Procedimiento de seguridad TIC es de aplicación, con carácter obligatorio, sobre todos los sistemas TIC responsabilidad de SPIKA TECH, servicios y procesos de negocio, activos de información y sus dependencias, personal interno o externo que tenga acceso información o sistemas de SPIKA TECH (con independencia de que exista o no una relación de carácter laboral) y, cualquier otra entidad involucrada con SPIKA TECH en la utilización de su información y sus sistemas.

3 NORMATIVA APLICABLE

Es aplicable toda la normativa establecida en el documento de **RGS_1 NORMATIVA APLICABLE.xlsx.**, que se actualizara de forma periódica Las Políticas, Normas y Procedimientos dentro del alcance del SGSI, se actualizarán, si procede, en base a los cambios normativos que pudieran afectar.

4 METODOLOGÍA DE GESTIÓN DE RIESGOS DESARROLLO

4.1 GESTIÓN DE NO CONFORMIDADES

Las no conformidades pueden ser detectadas por cualquier usuario de SPIKA TECH, aunque principalmente serán identificadas por los usuarios que intervengan en la propia gestión del sistema de seguridad de la información implantado.

4.2 DETECCIÓN E IDENTIFICACIÓN DE NO CONFORMIDADES

Cualquier usuario que intervenga en el sistema de gestión implantado que detecte una no conformidad deberá proceder a su comunicación tan rápido como sea posible. Para ello se deberá informar a SPIKA TECH sobre dicha no conformidad. El canal para la comunicación de la no conformidad será el siguiente: incidencias@spikatech.com

4.3 EVALUACIÓN DE NO CONFORMIDADES

Desde SPIKA TECH se valorará la gravedad de la no conformidad detectada. Dependiendo de la criticidad, la no conformidad puede ser categorizada en estos tipos:

- **Alto:** la actividad se ve paralizada y/o supone un grave daño en la organización (económico, pérdida de imagen, pérdida de cliente, etc.).
- **Medio:** No afecta al cliente, pero supone un esfuerzo extra de recursos para solucionarlo.
- **Bajo:** No afecta al proceso de trabajo de sistema de gestión implantado y tiene una solución inmediata.

En cualquier caso, se identificará el tratamiento que se debe dar para subsanar dicha no conformidad, así como el responsable de dicho tratamiento. Finalmente se detallará el plazo máximo de ejecución y se le comunicará a tal efecto al responsable de tratar la No Conformidad, cuando el impacto sea alto, o cuando la no conformidad sea repetitiva, se notificará inmediatamente al Responsable del SGSI para que éste decida un tratamiento adecuado.

4.4 TRATAMIENTO DE LAS NO CONFORMIDADES

Para registrar las no conformidades se usará el formato de plantilla que se encuentra en "PNT-006 Gestión de acciones correctivas y preventivas".

Cuando se detecte una no conformidad es imprescindible identificar su causa raíz como parte del método a emplear en la resolución de la misma, con el objetivo de intentar evitar la recurrencia o defecto identificando las causas que lo producen.

Para ello, se seguirán los siguientes pasos:

1. **Identificación de la NO CONFORMIDAD**. Se deberá recoger de forma clara y precisa la no conformidad detectada. Se debe detallar, en cualquier caso, el origen de la no conformidad. Además, se debe involucrar a todos los usuarios para que alerten de forma inmediata en el caso de que la NO CONFORMIDAD pudiese llegar a ser considerada como de criticidad alta.
2. **Conformar un equipo de respuesta.** Involucrar a aquellos usuarios de SPIKA TECH que se encuentren involucrados con la NO CONFORMIDAD detectada.
3. **Hallar la causa raíz del problema.** Enumeración de las posibles casus raíz del problema, se podría utilizar la metodología de los 5 porqués:
    - **Reunir a un equipo de personas** que comprenda el área donde se presentó la no conformidad y, a poder ser, que se hayan visto afectadas por el problema de forma directa.
    - **Descripción del problema,** junto con el equipo de personas reunidas, delimitar y establecer todos los detalles que han podido dar lugar al problema o no conformidad detectada.
    - **Hacer que los miembros del equipo se pregunten *por qué*** el problema ha ocurrido y anotar la respuesta junto con toda la información recopilada hasta entonces.
    - **Repita la operación,** con la fundamentación del por qué ha ocurrido o lo que ha causado el problema, detallar toda la información que se vaya obteniendo.
    - **Consulta al equipo** para determinar si se ha encontrado la causa raíz del problema. Debe ser de común acuerdo y lográndose una unanimidad.
4. **Diseño e implementación de acciones correctivas.** Una vez la causa raíz se encuentra detallada y planteada, se deberán tomar las decisiones oportunas acerca de lo que se va a cambiar y los roles que van a llevar a cabo las acciones.
5. **Observación y seguimiento de las acciones correctivas.** Se iniciará un proceso de revisión y supervisión donde se involucren a todos los usuarios que han formado parte de la implementación de acciones correctivas.

La aplicación de las acciones correctivas se decidirá por el Responsable del SGSI, atendiendo a los criterios expuestos a continuación:

- Si la no conformidad es repetitiva (se produce más de 3 veces en un período de un año) dará lugar a una acción correctiva.
- Si el impacto de la no conformidad es alto o crítico y no tiene asociado un plan de mitigación, se dará lugar a una acción correctiva.

4.5 MITIGACIÓN DE LA NO CONFORMIDAD

Hasta que la no conformidad haya sido resuelta las acciones a seguir sobre los elementos implicados en la misma será:

- Cuando la no conformidad haya sido sobre un activo, se buscarán medidas de mitigación, como el apagado, limitación de la conectividad interna o externa, aislamiento, añadir capas de seguridad adicionales, etc.
- Si se trata de no conformidades en actividades, procesos o productos, se evitará en la medida de lo posible su ejecución y/o utilización, hasta llevar a cabo el tratamiento de la no conformidad. El responsable del tratamiento asignado deberá mantener informado al personal implicado en todo momento de la situación o estado de la no conformidad.

4.6 SEGUIMIENTO Y CIERRE

Tras el tratamiento, y llegado el plazo máximo de ejecución establecido anteriormente, el Responsable del SGSI verificará que éste haya sido aplicado con eficacia y en el tiempo estipulado, para ello recogerá todas las evidencias posibles como pruebas de cumplimiento.

Cuando se proceda a cerrar una no conformidad, se deberá comprobar que ésta no tenga acciones correctivas asociadas. En el caso de que las tuviese, se deberá verificar el seguimiento de dichas acciones y comprobar que también estén cerradas. No se podrán cerrar no conformidades con acciones correctivas asociadas abiertas

5 REGISTROS Y ARCHIVOS

	Nombre del registro	Versión y Modificaciones
REGISTRO	**N/A**	N/A

6 REFERENCIAS

- ISO 27001:2022:
    - 10.2 No conformidad y acción correctiva.